

Solicitação de Proposta

Edital

Prestação de serviços para implementação de DevSecOps no ambiente Azure (ADO)

Escopo técnico de serviços

Solicitação de Proposta

Este documento e suas informações são confidenciais e constituem propriedade da BAT Latam South.

Exceto com a expressa autorização escrita da BAT Latam South, este documento ou a informação contida não poderá ser publicada, revelada, ou usada para qualquer outro propósito que não a preparação de uma resposta a ser submetida ao processo de seleção de fornecedor para o projeto em questão.

Conteúdo

1.	ESCOPO DE SERVIÇOS	3
1.1.	ESCOPO DE APLICAÇÃO.....	3
1.2.	CI/CD COM FOCO EM AZURE DEVOPS (E MULTIPLATAFORMA)	4
	<i>Ferramentas Complementares</i>	<i>4</i>
1.3.	MONITORAMENTO E OBSERVABILIDADE EM MICROSERVIÇOS.....	4
	<i>Padrões e Boas Práticas.....</i>	<i>5</i>
1.4.	COMPLIANCE E SEGURANÇA (PROTOCOLOS E BOAS PRÁTICAS)	5
	<i>Segurança no Pipeline (DevSecOps).....</i>	<i>5</i>
1.5.	HABILIDADE DE ATUAÇÃO EM REUNIÕES INTERNACIONAIS (INGLÊS).....	6
1.6.	HABILIDADES COMPLEMENTARES (DIFERENCIAIS)	6
1.7.	RESUMO PARA AVALIAÇÃO DE MATURIDADE DA EMPRESA.....	7
2.	AMBIENTE DEVSECOPS.....	7
3.	PROPOSTA COMERCIAL.....	8
4.	RESPONSABILIDADES DO FORNECEDOR	8
5.	FERRAMENTAL DE TRABALHO	9
6.	LOCAL DE PRESTAÇÃO DOS SERVIÇOS.....	9

1. ESCOPO DE SERVIÇOS

O escopo desta contratação, foco desta Solicitação de Proposta, abrange a **implementação de atividades para criar ambiente de DevSecOps para aplicações da BAT**, contemplando atividades operacionais, táticas e de melhoria contínua voltadas à estabilidade, disponibilidade, segurança e evolução controlada dos serviços de TI que suportam o negócio.

O proponente deverá seguir as melhores práticas metodológicas e padrões de mercado aplicáveis à sustentação.

O atendimento e escopo do serviço se aplicam exclusivamente à BAT Latam South.

1.1. Escopo de aplicação

Dado uma aplicação composta por:

- Dois micros serviços de backend (Java), autocontidos para container.
- Um frontend PWD\SPA (Flutter).
- Um banco de dados relacional SQL (Postgres).
- Um banco de dados NoSQL para cache (Redis).
- Duas APIs externas para consulta de dados (Serasa e Sefaz)

Estimar tempo e custo para a implementação e documentação de uma esteira DevSecOps no Azure DevOps que contenha, ao menos, os seguintes passos abaixo:

Item	Descrição
1	Criação e configuração de repositórios no Azure DevOps.
2	Implementar GitFlow Workflow como Software Versioning .
3	Criar usuários para provedores terceiros de dev.
4	Implementar Pipeline para execução dos Unit Tests .
5	Implementar Sonar e Lint para Code Quality .
6	Implementar Pipeline para empacota as aplicações (Container Image, APK, Lib, etc.)
7	Implementar Pipeline para execução dos E2E Tests .
8	Implementar Pipeline de deploy em UAT Env .
9	Implementar Pipeline de deploy em REG Env .
10	Implementar Pipeline de deploy em PRD Env .
11	Implementar monitoramento de Apps Uptime e Reath Check .
12	Implementar monitoramento de Links\Endpoint Uptime and Reath Check .

Item	Descrição
13	Implementar observabilidade com Logs and Metrics and Traces .
14	Implement\provide IaaS or PaaS infrastructure.
15	Implementar monitoramento dos componentes da aplicação (Servises, Databases e etc.)

1.2. CI/CD com Foco em Azure DevOps (e multiplataforma)

Necessidades Técnicas:

Área	Habilidades Específicas
Azure DevOps	Criação e manutenção de Pipelines \(\YAML\); uso de variable groups, library, service connections (Kubernetes, Docker Registry, Azure RM); integração com Azure Repos e Artifacts ; aprovações em produção (gates, approvals).
Multiplataforma	Capacidade de implementar pipelines equivalentes no GitLab CI (.gitlab-ci.yml, runners, environments) e GitHub Actions (workflows, self-hosted runners, actions marketplace).
Estratégias de CI	Build, testes unitários, testes de integração, análise estática (SonarQube, Checkmarx, etc.), linting de código e segurança em containers (Trivy, Snyk).
Estratégias de CD	Blue-green, canary, rolling update, feature flags; rollback automatizado; deploy multi-ambiente (dev, homolog, prod).
Gerenciamento de versões	Semantic Versioning, tagging automática, changelog automatizado.

Ferramentas Complementares

- Jenkins ou similar (para cenários híbridos)
- ArgoCD (GitOps)
- Helm (para Kubernetes)

1.3. Monitoramento e Observabilidade em Microserviços

Necessidades Técnicas:

Prática	Habilidades
---------	-------------

Prática	Habilidades
Métricas	Prometheus + Grafana; Azure Monitor; criação de SLIs/SLOs; dashboards com indicadores técnicos e/ou negócios (KPI).
Logs centralizados	ELK Stack (Elasticsearch, Logstash, Kibana), Loki ou análogos; correlação de logs com traces.
Distributed Tracing	OpenTelemetry, Jaeger, Zipkin; propagação de contexto entre microserviços.
Alertas	Definição de alertas críticos (latência, erro, saturação); integração com serviços de mensageria como Slack, MS Teams, Telegram e etc.
Health checks	Probes (liveness, readiness, startup) em Containers; Pods; endpoints de health personalizados.

Padrões e Boas Práticas

- **RED method** (Rate, Errors, Duration)
- **USE method** (Utilization, Saturation, Errors)
- **Service Level Objectives (SLOs) com error budgets**

1.4. Compliance e Segurança (Protocolos e Boas Práticas)

Necessidades Técnicas:

Requisito	Habilidades
LGPD / GDPR	Mapeamento de dados pessoais; logs de acesso; consentimento e anonimização.
SOC 2 / ISO 27001	Controles de acesso, auditoria de mudanças, segregação de ambientes.
Retenção de logs	Políticas definidas para trilha de auditoria (ex.: 12 meses).

Segurança no Pipeline (DevSecOps)

Prática	Habilidades
SAST/DAST	Ferramentas como SonarQube, Checkmarx, OWASP ZAP integradas ao pipeline.
SCA (Software Composition Analysis)	Snyk, Dependabot, WhiteSource para vulnerabilidades em bibliotecas.

Prática	Habilidades
Secrets management	Azure Key Vault, HashiCorp Vault, GitHub Secrets, GitLab CI/CD variables protegidas.
Container security	Assinatura de imagens (Cosign), escaneamento (Trivy, Gype), políticas de admissão (OPA/Gatekeeper).

1.5. Habilidade de Atuação em Reuniões Internacionais (Inglês)

Necessidades Técnicas:

Nível	Descrição
Compreensão auditiva	Entender sotaques variados (EUA, Reino Unido, Índia, Europa) em discussões técnicas.
Expressão oral	Explicar arquitetura de microsserviços, pipelines e decisões de observabilidade em inglês técnico.
Vocabulário específico	CI/CD, rollback, canary, tracing, SLO, error budget, compliance, security gate, threat model, etc.
Mediação de conflitos	Saber negociar prazos, justificar mudanças de pipeline, discutir vulnerabilidades encontradas.
Documentação em inglês	Criar e manter runbooks, playbooks de incidente, post-mortems e RFIs.

1.6. Habilidades Complementares (Diferenciais)

Necessidades Técnicas:

Área	Habilidades
Kubernetes	Operação de clusters (AKS, EKS, GKE), Helm, Kustomize, Service Mesh (Istio, Linkerd).
Mensageria	RabbitMQ, Kafka, Azure Service Bus – monitoramento de filas, dead-letter, latência.
Cultura SRE	Post-mortems sem blame, toil reduction, análise de tendências de incidentes.
Automação de	Testes de contrato (Pact), testes de carga (k6, JMeter) integrados ao pipeline.

Área	Habilidades
qualidade	

1.7. Resumo para Avaliação de Maturidade da Empresa

Necessidades Técnicas:

Dimensão	Nível desejado
CI/CD	Automação completa (dev → prod), rollback automático, multiplataforma.
Observabilidade	Tracing + métricas + logs correlacionados, alertas acionáveis.
Segurança	DevSecOps com gates automáticos, secrets management, escaneamento contínuo.
Compliance	Políticas documentadas e auditáveis (logs, acesso, retenção).
Inglês	Comunicação técnica fluente em reuniões globais.

2. AMBIENTE DEVSECOPS

A BAT Latam South tem como pré-requisitos para este escopo de serviço os seguintes critérios:

- A BAT Global possui parceria com a Microsoft e por padrão será necessário criar as aplicações conforme o ADO (Azure Dev Ops) da BAT;
- O Fornecedor entende que não terá acesso admin aos portais do ADO, e, portanto, necessitará seguir o fluxo para criação e configuração dos ambientes juntamente com o time global da BAT;
- O Fornecedor deverá seguir rigorosamente os padrões, normas, procedimentos e políticas da BAT, respeitando nível de acesso, e seguindo as documentações conforme solicitadas;
- A BAT define 3 níveis de controle, na qual o fornecedor propõem se a lidar na criação e configuração de novas aplicações, sendo elas:
 - **Nível de Plataforma:** Controlado via políticas da BAT ADO e Gerenciado pelo Coe (CenterOfExcelence) da BAT Global
 - **Nível de Organização (BATDIGITAL):** Governança centralizada pelo time da BAT ADO COE e as mudanças são encaminhadas através de processo de change management
 - **Nível de Projeto (aplicação):** Este nível é gerenciado pelo Product owner e

Project team; é implementação dos controles de forma local;

Considerando estes três níveis o fornecedor entende que precisará desenhar, preparar as necessidades e submeter as changes para que o time global aprove e faça as implementações nos níveis 1 (Plataforma) e 2 (organização)

3. PROPOSTA COMERCIAL

A BAT Latam South espera receber para atendimento deste serviço técnico duas composições de valor sendo:

Considerar um valor comercial para criação de uma nova aplicação o no modelo DEVSECOPS, considerando os itens constante no item 1.1 Escopo de Aplicação;

Valor por inclusão	Valor R\$	Qtd Horas Estimado
Aplicação 01		

Além do valor de inclusão e novas aplicações na esteira de DEVSECOPS, é importante ter uma tabela de valores de serviços especializados, que será utilizado para futuras manutenções nas esteiras já existentes, sendo elas por mudanças de regras, novos passos ou controles ou mesmo manutenção corretiva. A tabela de serviço deve ser considerada por valor Hora.

Valor por inclusão	Valor R\$ / hora	Valor R\$ / Hora fora horário comercial
Serviço Junior		
Serviço Pleno		
Serviço Senior		
Serviço Especialista		
....		

4. RESPONSABILIDADES DO FORNECEDOR

A BAT Latam South entende que serão de responsabilidade do fornecedor:

- Caso aplicável, manter e prover toda documentação referente a EHS / procedimentos de segurança para acesso dos colaboradores às filiais da BAT Latam South conforme política existente de cada localidade (detalhamento será enviado após definição do fornecedor);
- Prover equipamento (Laptop, celular ou outro equipamento), além de todo licenciamento necessário para operação do serviço para seus colaboradores, permitindo e-mail, Microsoft Teams, Sharepoint etc. sem ônus para a BAT Latam South, caso necessário (vide detalhes em Ferramental de trabalho).
- Prover treinamento contínuo para toda equipe, para adequação às tecnologias utilizadas pela BAT Latam South, suas evoluções e eventuais mudanças nas plataformas.
- Buscar aprimoramento contínuo de toda a equipe buscando otimizar e agilizar as ações e

atividades, escopo desta RFP.

- Fornece, de acordo com o formato e a periodicidade definidos em comum acordo com a BAT Latam South, os relatórios e os indicadores do serviço prestado.
- Participar das reuniões de gerência de mudanças da BAT Latam South, quando cabível, visando contribuir tecnicamente com o conteúdo das informações, chamados e/ou ordens de serviço.

5. FERRAMENTAL DE TRABALHO

A BAT Latam South entende que todo ferramental de trabalho para prestação de serviço tais como: posição de trabalho (mesa, cadeira, materiais de apoio) ou qualquer outro utensílio deve ser provido pelo fornecedor. Da mesma forma que equipamentos como Notebook, celulares, tablets, softwares (sistema operacional, licenciamento Office e outros) ou outros componentes devem fazer parte do escopo do serviço e ser de responsabilidade do fornecedor.

A BAT Latam South apenas gerenciará contas de acesso às plataformas da BAT, e em caso de inserir licenciamento nessas plataformas, isso será de responsabilidade da BAT. Qualquer outra plataforma de terceiros ou que não dependam de aprovação da BAT não será concedida.

6. LOCAL DE PRESTAÇÃO DOS SERVIÇOS

Todos os serviços contidos neste documento deverão ser prestados remotamente e de dentro das dependências do fornecedor, e com a gestão feita pelo fornecedor.